



SECURE KUBERNETES ON AZURE

How I designed, deployed, broke, diagnosed and fixed
a private AKS platform on real Azure infrastructure

DEV + PROD · BOTH VERIFIED LIVE

What I Built

I built a containerized web application on a private Azure Kubernetes Service cluster. It sits behind a WAF-enabled Application Gateway, pulls images from a private container registry, and is deployed by GitHub Actions using OIDC, so there are no long-lived credentials anywhere in the pipeline.



2

Independent
environments



0

Stored credentials
in the pipeline



PRIVATE

API server —
no public IP

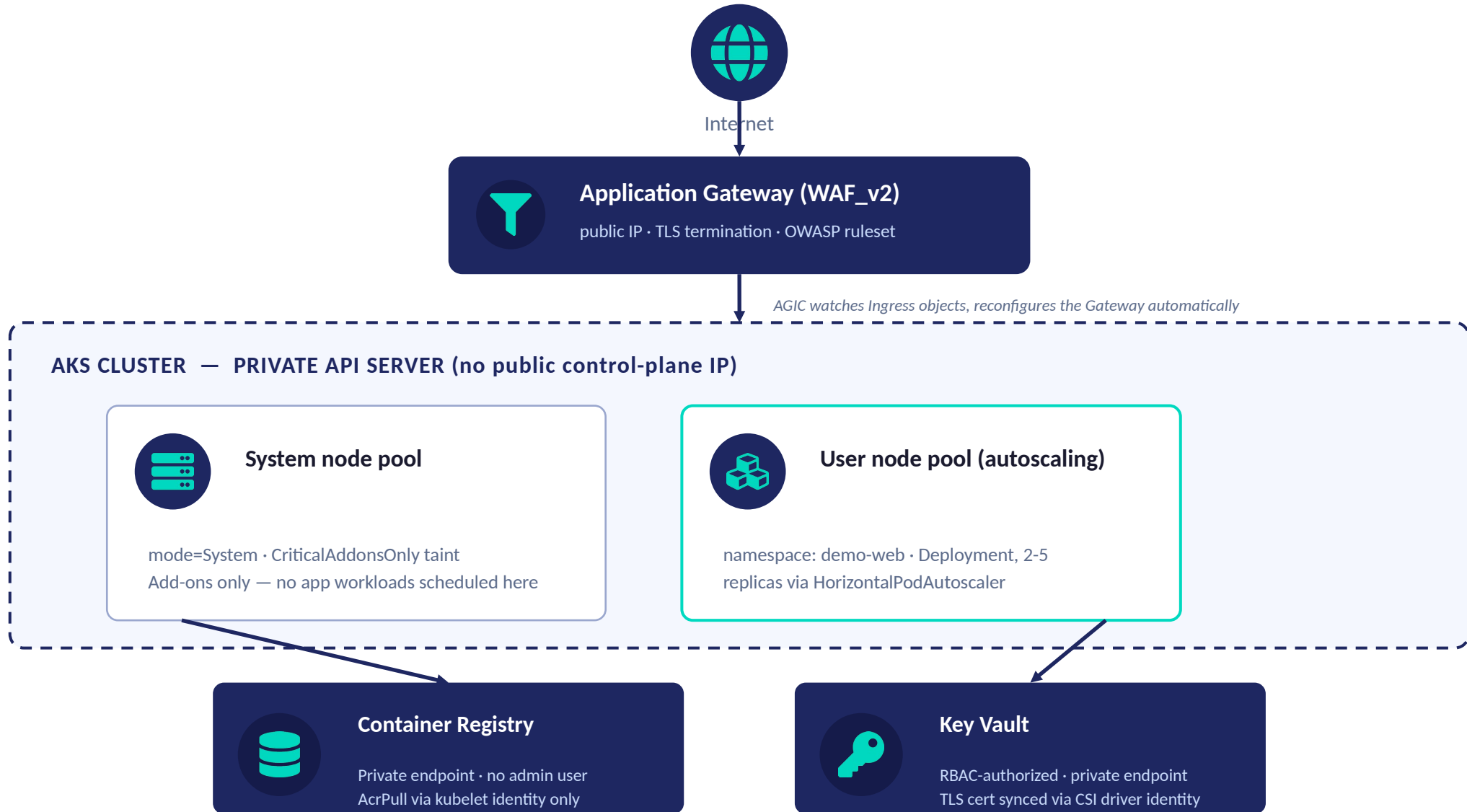


5-LAYER

Real incident,
diagnosed live

I verified both environments end to end on 2026-09-18: real pods, real TLS, a real public IP and a real HTTP 200.

Architecture: how a request travels



Inside the Cluster

The Kubernetes objects I deployed, and what each one does for me



Namespace

demo-web — isolates the app's objects, RBAC, and network policy



Deployment

2-5 replicas, non-root, read-only rootfs, all capabilities dropped



Service

Stable ClusterIP — what the Ingress and Gateway actually target



Ingress + AGIC

Declares routing intent; AGIC drives the real Application Gateway



HorizontalPodAutoscaler

Scales on CPU utilization (target 70%) with zero manual steps



NetworkPolicy (×3)

Default-deny; explicit allow only from the Gateway subnet + DNS



SecretProviderClass

Bridges the CSI driver to Key Vault — no cert material in Git

How I Locked It Down



Private API server

No public control-plane IP, anywhere



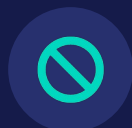
OIDC-only CI/CD

Federated tokens — zero stored Azure secrets in GitHub



Azure RBAC + Entra ID

Cluster access is group membership, not a static kubeconfig



Default-deny NetworkPolicy

Explicit allow only from the Gateway; egress limited to DNS



Non-root everywhere

Read-only rootfs, dropped capabilities, seccomp RuntimeDefault



No embedded credentials

ACR, Key Vault, and Gateway access all via managed identity

From git push to a running pod



Why I built it this way: a GitHub-hosted runner has no network route into a private cluster. So I use “az aks command invoke”, which runs kubectl through Azure itself. No VPN, no self-hosted runner and no Bastion host.



The Day Prod Broke

My prod app sat in ContainerCreating for over 24 hours and I hadn't noticed. Here is how I found it, five layers deep.

1

Invalid vault name: "REPLACE_WITH_KEY_VAULT_NAME"

Prod's overlay was missing a patch dev already had

2

ForbiddenByRbac

Admin identity lacked Key Vault Certificates Officer on that vault

3

ForbiddenByConnection

Vault is private by design — no VPN/Bastion path in, even for an authorized identity

4

SecretNotFound (404)

The TLS certificate simply didn't exist in prod's vault yet

5

InvalidImageName

A manual kustomize apply bypassed CI's image-substitution step mid-recovery

Full root-cause timeline: docs/webplat-architecture.md → "Incident: prod SecretProviderClass never patched"

Kubernetes in Plain Language

The terms I'll use today, explained the way I use them in this project

Pod

The smallest deployable unit — one or more containers sharing network/storage

Deployment

Declares “I want N copies running” and reconciles reality toward that

Service

A stable network identity for pods, even as pod IPs come and go

HPA

Horizontal Pod Autoscaler — changes replica count based on live metrics

Managed Identity

An Azure AD identity Azure manages the credential for — no key to leak

Node

A VM that runs pods — here, an Azure VM Scale Set instance

ReplicaSet

The Deployment's mechanism — a new one on every pod-template change

Ingress

A declarative routing rule; needs a controller (AGIC) to act on it

CSI driver

A plugin standard for mounting external storage/secrets into pods

Private cluster

The Kubernetes API server has no public IP at all

Where I'd Use This Pattern



Company websites with an SLA

Where “the site is down” is a business incident, not an inconvenience



Private line-of-business apps

Need network isolation but still a public-facing front door



Client engagement reference

Every piece answers a security-conscious procurement checklist



Multi-environment platforms

Each environment isolated at the network level, not just namespaced



Proof, Not Just Claims

Everything below was captured from my own Azure tenant, not mocked up

● ● ●

curl — prod

```
HTTP/1.1 200 OK
Server: nginx/1.27.5

$ curl .../healthz
ok
```

● ● ●

kubectl get pods — prod

```
demo-web-ccc969478-8cmfs
1/1 Running
demo-web-ccc969478-lmgm2
1/1 Running
```

● ● ●

App Gateway backend health

```
10.31.0.103 Healthy
10.31.0.136 Healthy

(both environments)
```

```
sufideen@sufillinux:~/Documents/repos/az-ent-sec-dashboard$ az aks command invoke --resource-group rg-itsolutions-webplat-prod-uks-001 --name aks-itsolutions-webplat-prod-uks-001 --command "kubectl get nodes"
command started at 2026-09-18 10:22:48+00:00, finished at 2026-09-18 10:22:48+00:00 with exitcode=0
NAME                                STATUS    ROLES    AGE   VERSION
aks-system-15120143-vmss000000      Ready    <none>    22h   v1.36.3
aks-system-15120143-vmss000001      Ready    <none>    22h   v1.36.3
aks-system-15120143-vmss000002      Ready    <none>    22h   v1.36.3
aks-user-21263827-vmss000000        Ready    <none>    22h   v1.36.3
aks-user-21263827-vmss000001        Ready    <none>    22h   v1.36.3
```

kubectl get nodes on prod, run through az aks command invoke: 3 system and 2 user nodes, all Ready

☐	rg-itsolutions-seccops-dev-uks-001	...	ict-cloud.solutions	UK South
☐	rg-itsolutions-webplat-dev-uks-001	...	ict-cloud.solutions	UK South
☐	rg-itsolutions-webplat-prod-uks-001	...	ict-cloud.solutions	UK South
☐	rg-nodes-aks-itsolutions-webplat-dev-uks-001	...	ict-cloud.solutions	UK South
☐	rg-nodes-aks-itsolutions-webplat-prod-uks-001	...	ict-cloud.solutions	UK South

Azure portal: dev and prod resource groups, plus the AKS-managed node groups

What I'd point out

Both environments are live and separate. Twelve pieces of evidence are in the repo: node health, private DNS, pods, backend health, end-to-end curl and Defender inventory, for dev and prod.



Let's Talk

- ✓ Private AKS + Azure networking design
- ✓ Zero-secret CI/CD with OIDC federation
- ✓ Live production incident diagnosis
- ✓ Infrastructure as Code (Bicep) at scale

Sufyan Deen-Gabisi

github.com/sufideen/az-ent-sec-dashboard

The full write-up, evidence and runbook are in the docs/ folder of the repository